Ethical Hacking - Assessment Tool I: MCQ (With Answers)

Course Code: ITA14 | CO1 | Correct options are shown in green with a ✓ and a short reason.

Part A: Questions 1 to 25

1. A company authorizes a security professional to test only its web server. During testing, the professional notices another vulnerable database server. What should the ethical hacker apply in this situation?

A) Test the database immediately
B) Remain within the authorized scope and report the observation ✓
C) Exploit the database to verify the weakness
D) Download the database for analysis

Reason: Testing must stay within the authorized scope; out-of-scope findings are reported, not exploited.

2. A security tester receives written permission to assess a company network. Which action should the tester perform first to apply ethical hacking principles?

A) Launch vulnerability exploits
B) Review the authorized scope and rules of engagement ✓
C) Disable the firewall
D) Collect employee passwords

Reason: The scope and rules of engagement define what is allowed, so they come first.

3. An ethical hacker discovers confidential customer information during an authorized penetration test. How should the hacker apply confidentiality principles?

A) Copy the information to a personal device
B) Share it with other testers outside the project
C) Protect the information and follow the agreed reporting procedure ✓
D) Publish the information as evidence

Reason: Confidential data must be protected and handled only per the agreement.

4. A student wants to practice vulnerability scanning on the college network. How should ethical hacking principles be applied?

A) Scan the network without informing anyone
B) Obtain authorization before performing the scan ✓
C) Scan only during the night
D) Hide the source IP address

Reason: Authorization is required before any scanning, even on a network you study on.

5. During an authorized assessment, a tester identifies a critical vulnerability. Which action applies responsible disclosure correctly?

A) Post the vulnerability publicly immediately
B) Report it securely to the authorized organization ✓
C) Sell the information
D) Ignore the vulnerability

Reason: Responsible disclosure means reporting privately to the owner so it can be fixed.

6. A penetration tester is authorized to test IP addresses 192.168.1.10–192.168.1.20. Which target can the tester ethically assess?

A) 192.168.1.5
B) 192.168.1.25
C) 192.168.1.15 ✓
D) 192.168.2.10

Reason: Only 192.168.1.15 falls inside the .10 to .20 range.

7. A tester accidentally gains access to sensitive payroll records during an assessment. What should the tester do?

A) Modify the records to demonstrate access
B) Download all records
C) Minimize further access and report the finding ✓
D) Share screenshots publicly

Reason: Limit exposure and report; never copy, alter or publish the data.

8. A company asks an ethical hacker to assess its website without affecting normal users. Which approach should the hacker apply?

A) Perform only approved, controlled, non-destructive testing ✓
B) Shut down the website
C) Delete vulnerable files
D) Modify customer accounts

Reason: Non-destructive, approved testing avoids harming availability and users.

9. An employee discovers a security flaw in the organization's internal application. How should proper disclosure be applied?

A) Publish the flaw online
B) Report it through the organization's approved security channel ✓
C) Exploit the flaw repeatedly
D) Inform unrelated organizations

Reason: Use the official internal reporting channel.

10. A tester is given authorization that expires at 6:00 PM. At 6:15 PM, testing is incomplete. What should the tester do?

A) Continue until testing is finished
B) Stop testing and obtain renewed authorization before continuing ✓
C) Continue without recording the activity
D) Change the system time

Reason: Testing after authorization expires is unauthorized; get it renewed first.

11. A security professional wants to demonstrate the impact of a vulnerability. Which action best applies ethical hacking practice?

A) Cause maximum possible damage
B) Use the least harmful approved method to demonstrate the risk ✓
C) Delete system files
D) Publish confidential data

Reason: Show risk with minimal harm, using approved methods.

12. A penetration tester discovers login credentials while performing an authorized assessment. How should the credentials be handled?

A) Store them publicly
B) Use them on unrelated systems
C) Protect them and use them only as permitted by the assessment scope ✓
D) Share them with friends

Reason: Credentials are sensitive and may only be used as the scope permits.

13. A company permits testing of its web application but specifically prohibits denial-of-service testing. Which action should the tester take?

A) Perform denial-of-service testing anyway
B) Follow the restriction and avoid denial-of-service testing ✓
C) Perform it outside office hours
D) Ask another person to perform it

Reason: Restrictions in the rules of engagement must be followed.

14. An ethical hacker finds a vulnerability that could expose thousands of customer records. Which response correctly applies professional ethics?

A) Download all customer records
B) Document the vulnerability while minimizing exposure of customer data ✓
C) Publish sample customer records
D) Use the data for another project

Reason: Document the flaw without unnecessarily touching customer data.

15. A tester realizes that a scanning tool is sending requests to systems outside the approved IP range. What should the tester do?

A) Allow the scan to continue
B) Stop or reconfigure the scan to remain within scope ✓
C) Increase the scanning speed
D) Ignore the issue

Reason: Stay in scope; stop or reconfigure the tool immediately.

16. An organization hires a penetration tester to evaluate its network. Which document should be applied to determine permitted and prohibited activities?

A) Rules of engagement ✓
B) Employee attendance record
C) Software installation guide
D) Marketing report

Reason: The rules of engagement spell out permitted and prohibited actions.

17. A researcher discovers a vulnerability in a public website without prior authorization. What is the most appropriate ethical action?

A) Exploit it to determine its full impact
B) Avoid unauthorized exploitation and use the site's approved vulnerability-reporting process if available ✓
C) Download user information
D) Change the vulnerable code

Reason: Do not exploit; report through an official disclosure channel.

18. During testing, an ethical hacker finds evidence of an unexpected serious security issue. What should the hacker do?

A) Ignore it because it was unexpected
B) Follow the agreed escalation and reporting procedure ✓
C) Delete the evidence
D) Publish the evidence immediately

Reason: Serious findings go through the agreed escalation path.

19. A penetration tester completes an assessment and has temporary copies of sensitive data collected under authorization. What should be done according to the agreed data-handling policy?

A) Keep the data permanently
B) Transfer it to a personal computer
C) Securely retain or dispose of it according to the agreement ✓
D) Share it with students

Reason: Data is handled and disposed of according to the agreement.

20. A tester needs to verify a vulnerability that could potentially crash a production server. Which action best applies ethical principles?

A) Test it immediately on the production server
B) Follow the approved testing procedure and use a safe environment where possible ✓
C) Crash the server intentionally
D) Ignore all organizational restrictions

Reason: Use approved procedures and a safe environment to avoid outages.

21. An ethical hacker is asked to test employee awareness using simulated phishing. What should be established before conducting the exercise?

A) Authorization, scope, and approved procedures ✓
B) Employees' personal passwords
C) Access to personal email accounts
D) Permission from unrelated companies

Reason: Phishing simulations need authorization, scope and approved procedures.

22. A security tester discovers that the approved scope document contains unclear instructions about testing a particular server. What should the tester do?

A) Assume permission is granted
B) Obtain clarification before testing that server ✓
C) Attack the server anonymously
D) Test first and ask later

Reason: Ambiguity means ask first; never assume permission.

23. During an authorized assessment, a tester identifies a weak password on an account. Which action appropriately applies ethical hacking principles?

A) Post the password online
B) Use it only as authorized and document the weakness ✓
C) Use it to access unrelated accounts
D) Give it to other employees

Reason: Use it only within authorization and document it.

24. A company asks a security professional to prepare a report after testing. Which information should be included to support ethical disclosure?

A) Vulnerabilities, evidence, risk, and recommended remediation ✓
B) Personal opinions about employees
C) Unrelated customer information
D) Passwords for public distribution

Reason: A good report has findings, evidence, risk ratings and remediation.

25. A security team plans an ethical hacking assessment. Which sequence best applies ethical hacking principles?

A) Exploit → Obtain permission → Report → Define scope
B) Obtain authorization → Define scope → Test → Document → Report ✓
C) Scan → Publish → Obtain permission → Exploit
D) Attack → Collect data → Share → Delete evidence

Reason: Authorization first, then scope, testing, documentation and reporting.

Part B: Scenario-based Questions (numbered 26 onward)

26. A senior security researcher is hired to test a decentralized cryptocurrency exchange. During the engagement, they notice a marketing team's standalone server is highly vulnerable. The tester decides to execute a remote code execution payload to provide a more comprehensive report. Evaluate this decision from a legal and ethical standpoint.

A) It is ethically sound because it improves the client's overall security posture.
B) It is valid under standard ethical hacking frameworks provided no data is permanently deleted.
C) It is legally protected as long as the tester does not monetize or leak the findings.
D) It violates explicit authorization, risking severe legal liability and breaching ethical boundaries. ✓

Reason: Exceeding the authorized scope is unauthorized access, with legal liability, even if the intent is good.

27. While officially authorized to test a decentralized cryptocurrency exchange, an internal compliance auditor assumes the contract implicitly includes the building's physical security camera system and proceeds to attack it. Judge the legal validity of this assumption.

A) Ethically and legally dangerous; authorization must always be explicit, documented, and unambiguous. ✓
B) It is legally permissible as long as the actor is a certified and licensed professional.
C) It is standard practice to ensure no blind spots remain in the client's overall audit.
D) It is a valid assumption if both systems share the same internal IP subnet.

Reason: Authorization must be explicit and written; assumptions about scope are not a defence.

28. An independent ethical hacker is offered a contract to audit a federal tax web portal, but was rejected for a full-time role there last week. Judge the decision to accept this auditing contract.

A) Unethical due to a severe conflict of interest that compromises the auditor's objectivity. ✓
B) Legal and ethical, provided they sign a supplementary non-disclosure agreement.
C) Acceptable, as long as they only utilize automated scanning tools to remove bias.
D) Ethical, as their insider knowledge will result in a more thorough security test.

Reason: A conflict of interest compromises objectivity, so the engagement should be declined.

29. Following an engagement against a multi-national bank's mobile app, management strictly asks a corporate security consultant to delete any mention of the CEO's compromised email account in the final official report. Recommend the most ethical response.

A) Alter the report as requested, but leave a hidden cryptographic signature indicating tampering.
B) Refuse the request entirely to maintain the integrity, accuracy, and objectivity of the audit. ✓
C) Agree to the modification, but charge a premium fee for altering official compliance documents.
D) Comply with the request, as the client owns the report and retains final editorial rights.

Reason: Reports must stay honest and accurate; falsifying findings or dates breaches integrity.

30. Months after successfully finishing a penetration test on a decentralized cryptocurrency exchange, an internal compliance auditor decides to retain the database of unencrypted credit card transactions on a local home server 'just in case'. Critique this post-engagement practice.

A) It blatantly violates the ethical mandate for secure data destruction and strict confidentiality. ✓
B) It is ethically acceptable as long as the home server is disconnected from the public internet.
C) It is a standard industry practice to retain client data for long-term historical benchmarking.
D) It is legally required to prove the vulnerabilities existed in case of a future audit dispute.

Reason: Client data must be securely destroyed or returned per the agreement; keeping it breaches confidentiality.

31. A network security auditor is offered a contract to audit a logistics and shipping API, but is secretly building a competing software product. Judge the decision to accept this auditing contract.

A) Unethical due to a severe conflict of interest that compromises the auditor's objectivity. ✓
B) Legal and ethical, provided they sign a supplementary non-disclosure agreement.
C) Acceptable, as long as they only utilize automated scanning tools to remove bias.
D) Ethical, as their insider knowledge will result in a more thorough security test.

Reason: A conflict of interest compromises objectivity, so the engagement should be declined.

32. During a monitoring phase, a corporate security consultant detects an active, malicious attack against an online retail platform. They immediately respond by deploying a reverse-shell to delete the attacker's tools. Judge this defensive response.

A) It is legally protected under international self-defense doctrines for digital property.
B) It is ethically mandated to prevent further harm to the client's network infrastructure.
C) It is acceptable if local law enforcement is notified within 24 hours of the counter-attack.
D) It is illegal vigilantism (hacking back); ethical hacking does not authorize offensive actions against third parties. ✓

Reason: Hacking back is illegal vigilantism; an ethical hacker's authority covers only the client's own systems.

33. Months after successfully finishing a penetration test on a university's research database, a bug bounty participant decides to retain the medical records accessed during the test on a local home server 'just in case'. Critique this post-engagement practice.

A) It blatantly violates the ethical mandate for secure data destruction and strict confidentiality. ✓
B) It is ethically acceptable as long as the home server is disconnected from the public internet.
C) It is a standard industry practice to retain client data for long-term historical benchmarking.
D) It is legally required to prove the vulnerabilities existed in case of a future audit dispute.

Reason: Client data must be securely destroyed or returned per the agreement; keeping it breaches confidentiality.

34. While officially authorized to test a public transportation control system, a junior penetration tester assumes the contract implicitly includes a staging server that closely mirrors production and proceeds to attack it. Judge the legal validity of this assumption.

A) Ethically and legally dangerous; authorization must always be explicit, documented, and unambiguous. ✓
B) It is legally permissible as long as the actor is a certified and licensed professional.
C) It is standard practice to ensure no blind spots remain in the client's overall audit.
D) It is a valid assumption if both systems share the same internal IP subnet.

Reason: Authorization must be explicit and written; assumptions about scope are not a defence.

35. An internal compliance auditor is offered a contract to audit a regional hospital's network, but has a lucrative side-deal with their top competitor to leak data. Judge the decision to accept this auditing contract.

A) Unethical due to a severe conflict of interest that compromises the auditor's objectivity. ✓
B) Legal and ethical, provided they sign a supplementary non-disclosure agreement.
C) Acceptable, as long as they only utilize automated scanning tools to remove bias.
D) Ethical, as their insider knowledge will result in a more thorough security test.

Reason: A conflict of interest compromises objectivity, so the engagement should be declined.

36. A corporate security consultant identifies a vulnerability in an online retail platform without any prior permission and creates a video showing the hack but hides the company name. Classify the hacker profile and evaluate the action.

A) Hacktivism; aimed at political reform by exposing the company's weak security posture.
B) Black hat behavior; driven strictly by malicious intent and violation of the CIA triad.
C) Gray hat behavior; well-intentioned but legally perilous due to the strict lack of authorization. ✓
D) White hat behavior; entirely ethical and legal since the ultimate goal was system defense.

Reason: Good intent but no authorization makes it gray hat: not malicious, yet still legally risky.

37. An internal compliance auditor identifies a vulnerability in a regional hospital's network without any prior permission and fixes the flaw but leaves a harmless backdoor for themselves. Classify the hacker profile and evaluate the action.

A) Hacktivism; aimed at political reform by exposing the company's weak security posture.
B) Black hat behavior; driven strictly by malicious intent and violation of the CIA triad. ✓
C) Gray hat behavior; well-intentioned but legally perilous due to the strict lack of authorization.
D) White hat behavior; entirely ethical and legal since the ultimate goal was system defense.

Reason: Unauthorized access plus a hidden backdoor for personal access is malicious persistence, so black hat behavior.

38. During a monitoring phase, an independent ethical hacker detects an active, malicious attack against a federal tax web portal. They immediately respond by wiping the attacker's database of stolen credentials. Judge this defensive response.

A) It is legally protected under international self-defense doctrines for digital property.
B) It is ethically mandated to prevent further harm to the client's network infrastructure.
C) It is acceptable if local law enforcement is notified within 24 hours of the counter-attack.
D) It is illegal vigilantism (hacking back); ethical hacking does not authorize offensive actions against third parties. ✓

Reason: Hacking back is illegal vigilantism; an ethical hacker's authority covers only the client's own systems.

39. While assessing a logistics and shipping API, a network security auditor runs a customized payload generator without verifying its impact, which inadvertently locks out all legitimate administrative users. Assess the primary ethical failure in this scenario.

A) A breach of Non-repudiation, as the tool's execution logs were not preserved.
B) Failure to assess operational risk, directly violating the principle of Availability. ✓
C) A violation of Confidentiality, as the system outage likely exposed unencrypted data.
D) There is no ethical failure, as uncovering deep vulnerabilities inherently requires downtime.

Reason: Running unverified tools on production risks outages, a failure of operational risk management (Availability).

40. Upon discovering a severe flaw in a cloud storage provider, a network security auditor contacts the organization and demands $50,000 in Ethereum before providing the vulnerability report. Evaluate this action under ethical hacking laws.

A) It is ethically justified if the organization can easily afford the requested compensation.
B) This is an aggressive but legally recognized negotiation tactic within modern bug bounties.
C) This constitutes illegal extortion and is classified as malicious black-hat behavior. ✓
D) It is valid under full disclosure guidelines as compensation for the researcher's time.

Reason: Demanding payment under threat of withholding the report is extortion, unlike a voluntary bug bounty.

41. While assessing an online retail platform, a corporate security consultant runs a mass exploitation script without verifying its impact, which inadvertently crashes the primary production database. Assess the primary ethical failure in this scenario.

A) There is no ethical failure, as uncovering deep vulnerabilities inherently requires downtime.
B) A violation of Confidentiality, as the system outage likely exposed unencrypted data.
C) Failure to assess operational risk, directly violating the principle of Availability. ✓
D) A breach of Non-repudiation, as the tool's execution logs were not preserved.

Reason: Running unverified tools on production risks outages, a failure of operational risk management (Availability).

42. Following an engagement against a federal tax web portal, management strictly asks a freelance vulnerability assessor to falsify the date of the test to meet a regulatory deadline in the final official report. Recommend the most ethical response.

A) Alter the report as requested, but leave a hidden cryptographic signature indicating tampering.
B) Comply with the request, as the client owns the report and retains final editorial rights.
C) Agree to the modification, but charge a premium fee for altering official compliance documents.
D) Refuse the request entirely to maintain the integrity, accuracy, and objectivity of the audit. ✓

Reason: Reports must stay honest and accurate; falsifying findings or dates breaches integrity.

43. A bug bounty participant is offered a contract to audit a social media startup, but is currently suing the company for wrongful termination. Judge the decision to accept this auditing contract.

A) Unethical due to a severe conflict of interest that compromises the auditor's objectivity. ✓
B) Acceptable, as long as they only utilize automated scanning tools to remove bias.
C) Ethical, as their insider knowledge will result in a more thorough security test.
D) Legal and ethical, provided they sign a supplementary non-disclosure agreement.

Reason: A conflict of interest compromises objectivity, so the engagement should be declined.

44. While officially authorized to test a logistics and shipping API, a senior security researcher assumes the contract implicitly includes a third-party managed database physically located in the office and proceeds to attack it. Judge the legal validity of this assumption.

A) It is a valid assumption if both systems share the same internal IP subnet.
B) Ethically and legally dangerous; authorization must always be explicit, documented, and unambiguous. ✓
C) It is standard practice to ensure no blind spots remain in the client's overall audit.
D) It is legally permissible as long as the actor is a certified and licensed professional.

Reason: Authorization must be explicit and written; assumptions about scope are not a defence. A third-party system also needs the third party's consent.

45. A certified red teamer is hired to test a university's research database. During the engagement, they notice a physically separate HR network is highly vulnerable. The tester decides to deploy a ransomware simulator on it to provide a more comprehensive report. Evaluate this decision from a legal and ethical standpoint.

A) It is legally protected as long as the tester does not monetize or leak the findings.
B) It is ethically sound because it improves the client's overall security posture.
C) It is valid under standard ethical hacking frameworks provided no data is permanently deleted.
D) It violates explicit authorization, risking severe legal liability and breaching ethical boundaries. ✓

Reason: Exceeding the authorized scope is unauthorized access, with legal liability, even if the intent is good.

46. During a monitoring phase, a freelance vulnerability assessor detects an active, malicious attack against a university's research database. They immediately respond by launching a DDoS attack against the attacker's IP. Judge this defensive response.

A) It is legally protected under international self-defense doctrines for digital property.
B) It is acceptable if local law enforcement is notified within 24 hours of the counter-attack.
C) It is illegal vigilantism (hacking back); ethical hacking does not authorize offensive actions against third parties. ✓
D) It is ethically mandated to prevent further harm to the client's network infrastructure.

Reason: Hacking back is illegal vigilantism; an ethical hacker's authority covers only the client's own systems.

47. Following an engagement against a cloud storage provider, management strictly asks a network security auditor to change the root cause from 'negligence' to 'advanced threat' in the final official report. Recommend the most ethical response.

A) Agree to the modification, but charge a premium fee for altering official compliance documents.
B) Alter the report as requested, but leave a hidden cryptographic signature indicating tampering.
C) Refuse the request entirely to maintain the integrity, accuracy, and objectivity of the audit. ✓
D) Comply with the request, as the client owns the report and retains final editorial rights.

Reason: Reports must stay honest and accurate; falsifying findings or dates breaches integrity.

48. After discovering a critical flaw in a biometric authentication API, a freelance vulnerability assessor reports it privately. The vendor ignores the report for 9 months. Frustrated, the researcher decides to upload an automated exploitation script to GitHub. Critique this disclosure strategy.

A) It is ethical as part of the Coordinated Disclosure framework since the grace period expired.
B) It is unethical as it maximizes risk to the public without providing a viable mitigation path. ✓
C) It is legally acceptable because the vendor's silence automatically waives their copyright protections.
D) It is completely justified under the Full Disclosure model to force the vendor into action.

Reason: Releasing a ready-to-use exploit puts users at risk. Better options are escalating via CERT/CC or a coordinator, or publishing details without a weaponized exploit.

49. A network security auditor is hired to test a social media startup. During the engagement, they notice a deactivated test environment is highly vulnerable. The tester decides to create a new administrative account on it to provide a more comprehensive report. Evaluate this decision from a legal and ethical standpoint.

A) It is valid under standard ethical hacking frameworks provided no data is permanently deleted.
B) It violates explicit authorization, risking severe legal liability and breaching ethical boundaries. ✓
C) It is ethically sound because it improves the client's overall security posture.
D) It is legally protected as long as the tester does not monetize or leak the findings.

Reason: Exceeding the authorized scope is unauthorized access, with legal liability, even if the intent is good.

50. Months after successfully finishing a penetration test on a regional hospital's network, an independent ethical hacker decides to retain a complete dump of the customer database on a local home server 'just in case'. Critique this post-engagement practice.

A) It is legally required to prove the vulnerabilities existed in case of a future audit dispute.
B) It is ethically acceptable as long as the home server is disconnected from the public internet.
C) It is a standard industry practice to retain client data for long-term historical benchmarking.
D) It blatantly violates the ethical mandate for secure data destruction and strict confidentiality. ✓
Reason: Client data must be securely destroyed or returned per the agreement; keeping it breaches confidentiality.

51. A senior security researcher identifies a vulnerability in a public transportation control system without any prior permission and anonymously submits the finding to a public bug tracker. Classify the hacker profile and evaluate the action.

A) White hat behavior; entirely ethical and legal since the ultimate goal was system defense.
B) Hacktivism; aimed at political reform by exposing the company's weak security posture.
C) Black hat behavior; driven strictly by malicious intent and violation of the CIA triad.
D) Gray hat behavior; well-intentioned but legally perilous due to the strict lack of authorization. ✓
Reason: Good intent but no authorization and public posting makes it gray hat: well-intentioned yet legally and ethically risky.

Quick Answer Key

1-B	**2-B**	**3-C**	**4-B**	**5-B**	**6-C**	**7-C**
8-A	**9-B**	**10-B**	**11-B**	**12-C**	**13-B**	**14-B**
15-B	**16-A**	**17-B**	**18-B**	**19-C**	**20-B**	**21-A**
22-B	**23-B**	**24-A**	**25-B**	**26-D**	**27-A**	**28-A**
29-B	**30-A**	**31-A**	**32-D**	**33-A**	**34-A**	**35-A**
36-C	**37-B**	**38-D**	**39-B**	**40-C**	**41-C**	**42-D**
43-A	**44-B**	**45-D**	**46-C**	**47-C**	**48-B**	**49-B**
50-D	**51-D**					